Aran: post-quantum upgrade

Question: how should Aran use post-quantum cryptography (PQC), and where does it actually make Aran stronger?

Owners: Inbathamizhan S and Aasif Ahmed A (cyber security). Bharadhwaj M and SN Arun Vijay read sections 1 and 2.

Read first: Learn 14: Post-Quantum Cryptography, after Learn 3.

Code: `research/pqc/hybrid.py` (hybrid signatures and key sealing), `research/pqc/cbom.py` (CBOM scanner), `research/firewall/shredder.py` (receipts now hybrid), `research/experiment_pqc.py` (E17 to E19), `research/test_pqc.py` (9 tests). Raw numbers: `research/results_pqc.json`; CBOM: `research/pqc/cbom.json`. No new dependency: `cryptography` 50 ships ML-KEM and ML-DSA.

Summary

Most of Aran was already quantum-safe, because its core is symmetric: FF1 on AES, AES-256-GCM, HMAC-SHA256 and a SHA-256 Merkle log. Three things were not, and all three are now fixed.

Finding	Before	After
Erased values recoverable after a break of X25519, from one recorded night of key backups (E17, 1,200 erased values)	**100%**	**0%** with X25519 + ML-KEM-768 sealing
Erasure receipts forgeable by a quantum attacker	Yes (Ed25519 only)	No: Ed25519 + ML-DSA-65, both required; downgrade by stripping blocked
FF1 key strength against Grover, live console	64 bits (AES-128)	128 bits (AES-256), checked on NIST FF1 samples 7 and 8
Quantum-broken algorithms in product code (CBOM, E19)	Ed25519 (3 uses)	0; Ed25519 and X25519 appear only paired with ML-DSA / ML-KEM
Erasure receipt size (E18)	904 bytes	8,155 bytes
Receipt verifications per second, one core (E18)	5,657	1,930
Erasures per second (E18; dominated by token counting, not signing)	176	133
FF1 tokens per second (E18)	5,939 (AES-128)	5,787 (AES-256)

The new research result is the first row. Crypto-shredding (M5, Theorem 3) promises that destroying a key erases every copy everywhere. That promise has a hidden condition: **the key must never have travelled under quantum-breakable key exchange.** If it did, an attacker who recorded that traffic can un-erase the customer years later. We call this **retroactive un-erasure**, and to our knowledge it has not been pointed out for crypto-shredding before.

1. Inventory: what a quantum computer does to each part of Aran

Mechanism	Primitive	Shor	Grover	Verdict
M1/M3 checksum-complement and per-sink tokens	FF1 (AES), HMAC-SHA256 offsets	no effect	halves key bits	Safe with 256-bit keys. The live console used 128-bit keys; changed
M2 detector registries	HMAC-SHA256 in a cuckoo filter	no effect	256 to 128 bits	Safe
M4 leakage ledger	counting, no crypto			Safe
M5 vault	AES-256-GCM per customer per purpose	no effect	256 to 128 bits	Safe
M5 Merkle log	SHA-256 (RFC 6962)	no effect	collisions about 2^85 (BHT algorithm)	Safe
M5 erasure receipts	Ed25519	**breaks it**		Replaced by hybrid
Key backup / DR replication, TLS to sinks and to the AI gateway	X25519 or RSA in practice	**breaks it**		Replaced by hybrid
AI gateway audit log	SHA-256 hash chain	no effect		Safe

One more quantum attack was checked and set aside. Simon’s algorithm breaks 3- and 4-round Feistel ciphers in polynomial time, and FF1 is a Feistel cipher. But that attack needs the attacker to query the cipher **in quantum superposition**, which is impossible against a bank server that takes classical requests, and FF1 has 10 rounds. FF1 stays on the safe side.

2. Retroactive un-erasure (E17)

Setup. 1,000 generated customers, each with an Aadhaar number and a card number, tokenised for two purposes (Loans to a loan vendor, Marketing to a CRM). Purpose keys are backed up one night to a disaster-recovery site, sealed to the DR site’s public key. The attacker records two things: that sealed backup, and the vault’s ciphertext table (crypto-shredding says ciphertext copies are harmless once keys are gone). Then 300 customers ask for erasure of Loans and Marketing; the bank destroys those 600 keys at the primary and the DR site. After erasure the bank itself can read 0 of the 1,200 erased values, so the erasure works today.

Q-day. A quantum computer cannot be run here, so its effect is simulated: the attacker is handed the DR site’s X25519 private key, which is exactly what Shor’s algorithm computes from the public key. No quantum attack on ML-KEM is known, so the attacker gets nothing for that half and must guess it.

Backup sealed with	Backup size	Keys recovered	Erased values recovered
X25519 (today's common practice)	260,117 bytes	4,000 of 4,000	**1,200 of 1,200 (100%)**
X25519 + ML-KEM-768 hybrid	261,580 bytes	0	**0 (0%)**
Never exported (keys stay in an HSM)		0	0

The 100% and 0% follow by construction once the simulation's assumption is granted; the experiment is a working demonstration of the attack path, not evidence about quantum hardware. What it shows is that the gap is real, end to end, with Aran's own vault, and that the fix costs 1,463 bytes per backup.

Consequence for Theorem 3. The theorem should now read: tokens become anonymous once the key is destroyed, **provided every copy of the key that ever existed outside the vault was protected by quantum-safe key establishment, or the key never left a hardware boundary.** That makes PQC a precondition for DPDP-style erasure claims about data with a long shelf life, not an optional hardening. It also gives banks a simple rule: purpose keys should be generated and destroyed inside an HSM, and any replication between HSMs must use hybrid or post-quantum key transport.

3. Hybrid erasure receipts

`PurposeVault` now signs each receipt with Ed25519 and ML-DSA-65 over the same bytes. The receipt keeps its old fields (`signature`, `public_key`) and adds `alg`, `pq_signature` and `pq_public_key`, so old tools still read it.

- Both signatures must verify; the tests swap each half for another key's valid signature and both cases fail.
- `alg` is inside the signed bytes. Stripping the post-quantum half and presenting the receipt as an old Ed25519 one fails, because the Ed25519 signature covered the `alg` field.
- Old Ed25519-only receipts still verify by default. `verify_receipt(r, require_pq=True)` refuses them; a bank turns this on when it decides Ed25519 alone is no longer trustworthy.
- The live console shows both signatures and says when both verified.

Why ML-DSA-65 and not SLH-DSA: SLH-DSA rests only on hash functions, which makes it the most conservative choice, but its signatures are 7 to 50 KB and `cryptography` 50 does not ship it yet. Receipts already rest on SHA-256 through the Merkle log, so a later step could sign only the Merkle root with SLH-DSA, once per batch, and keep per-receipt signatures small. That is listed as future work.

4. Cost (E18)

One core, Python 3.13, `cryptography` 50.0.1 (OpenSSL 4.0.2), median of 200 to 500 runs.

Signature	Public key	Signature	Sign	Verify
Ed25519	32 B	64 B	40 µs	122 µs
ML-DSA-44	1,312 B	2,420 B	594 µs	163 µs
ML-DSA-65	1,952 B	3,309 B	1,188 µs	255 µs
ML-DSA-87	2,592 B	4,627 B	1,304 µs	369 µs

Key establishment	Public key	Ciphertext	Encapsulate	Decapsulate
X25519	32 B	32 B	75 µs	37 µs
ML-KEM-768	1,184 B	1,088 B	29 µs	43 µs
ML-KEM-1024	1,568 B	1,568 B	38 µs	57 µs
X25519 + ML-KEM-768	1,216 B	1,120 B	142 µs	90 µs

Post-quantum crypto is bigger, not slower: ML-KEM is faster than X25519. The visible costs are receipt size (9 times larger) and verification rate (about a third). At 1,930 verifications per second per core, a regulator checking a day of erasure receipts from a large bank needs seconds, not hours. The tokenising path (FF1) does not use public-key crypto at all, so the firewall's throughput is unchanged except for the switch to AES-256 (about 3% slower in E18).

5. What to migrate first (E19)

CBOM. `python -m pqc.cbom` scans the code and writes a CycloneDX 1.6 CBOM (`research/pqc/cbom.json`). India's quantum-safe task force (DST, February 2026) asks technology vendors for CBOMs from 2027 to 2028, so Aran can now produce one for itself and, pointed at a bank's Python services, for them. Before the upgrade it found Ed25519 (quantum-broken, 3 uses) and one 128-bit key (`app/server/engine.py`); after, no quantum-broken algorithm without a post-quantum partner and no 128-bit key in product code. The experiment scripts keep their 128-bit keys so that published results E1 to E16 stay reproducible. It is pattern matching, so it can miss indirect uses.

Mosca priority table. Exposure in years = shelf life + migration time - years to a quantum computer. Migration time is 7 years (2026 to 2033, India's standard-track date). Shelf lives are our assumptions.

Data	Shelf life (assumed)	Protected by	Exposed years if CRQC in 2032	in 2035	in 2040
Aadhaar number	70	key exchange	71	68	63
PAN	70	key exchange	71	68	63
Name and address	30	key exchange	31	28	23
Mobile number, UPI ID	10	key exchange	11	8	3
Erasure receipt	10	signature	11	8	3
Card number	5	key exchange	6	3	0
OTP	minutes	key exchange	(1)	0	0

The OTP’s 1 year in the 2032 column is an artefact of the formula: a quantum break that takes about a week (Gidney 2025) is useless against a value that expires in minutes. Everything else says the same thing: Aadhaar, PAN, names and addresses come first, and waiting for the machine is not an option for them.

6. Plan

Step	What	Who	Status
1	Inventory (CBOM) and Mosca table	Inbathamizhan, Aasif	Done (E19)
2	AES-256 for FF1 in the console	Inbathamizhan	Done
3	Hybrid erasure receipts with downgrade protection	Inbathamizhan, Aasif	Done (in `shredder.py`, console shows both)
4	Hybrid sealing for any key that leaves the vault	Aasif	Done as a library (`pqc/hybrid.py`); wire into a real backup job next
5	Hybrid TLS (X25519MLKEM768) in front of the console, the reverse proxy (roadmap item 1) and the AI gateway (item 6)	Aasif	Configuration only: nginx or Caddy built on OpenSSL 3.5+, `ssl_ecdh_curve X25519MLKEM768:X25519;`. Not tested here: the container's system OpenSSL is 3.0
6	Sign the Merkle root with SLH-DSA once per batch	Inbathamizhan	Future, when the library ships it
7	Run the CBOM scanner against a bank's services and report quantum-broken uses per data type, joined with the leakage ledger (M4) to rank flows by bits leaked times years exposed	Inbathamizhan, Aasif	Future research
8	Legal review: does "crypto-shredding with PQ key transport" satisfy DPDP erasure?	Team, with a lawyer	Open (same question as before, now with the precondition stated)

7. Limits, stated plainly

- No quantum computer was used. E17 simulates Shor by giving the attacker the X25519 private key. The result shows the attack path and the fix; it does not measure quantum hardware.
- Hybrid TLS is described, not tested in this environment.
- Mosca shelf lives are assumptions; the CRQC dates are scenarios, not forecasts.
- The CBOM scanner reads Python source by pattern; it does not see Java, C, HSM firmware or third-party services.
- ML-DSA and ML-KEM are young. That is why everything is hybrid: if either half falls, the other still protects the data.

Sources

- NIST FIPS 203, 204 and 205 (13 August 2024); NIST IR 8547 initial public draft (November 2024): quantum-vulnerable algorithms deprecated after 2030 and disallowed after 2035. Summary: https://www.encryptionconsulting.com/nist-ir-8547-2030-2035-action-plan/
- NIST SP 800-38G (FF1), sample vectors 7 and 8 (AES-256).
- C. Gidney, “How to factor 2048 bit RSA integers with less than a million noisy qubits”, arXiv:2505.15917, 2025. https://arxiv.org/abs/2505.15917v1
- Department of Science and Technology, Government of India, “Implementation of Quantum Safe Ecosystem in India: Report of the Task Force”, February 2026: CII full migration by 2029, banking and other sectors by 2033, CBOMs from 2027 to 2028. Summary: https://postquantum.com/security-pqc/indias-quantum-safe-roadmap/
- RBI Deputy Governor S. C. Murmu, Global FinTech Fest, 11 September 2026, as reported: https://www.qnulabs.com/blog/rbi-quantum-proof-payment-systems-2026
- M. Mosca, IEEE Security & Privacy 16(5), 2018.
- M. Barbosa et al., “X-Wing: The Hybrid KEM You’ve Been Looking For”, 2024; IETF draft-ietf-tls-ecdhe-mlkem (X25519MLKEM768). OpenSSL 3.5 default key share: https://postquantum.com/security-pqc/openssl-3-5-pqc-default/
- H. Kuwakado and M. Morii, “Quantum distinguisher between the 3-round Feistel cipher and the random permutation”, ISIT 2010 (Simon’s algorithm on Feistel ciphers, superposition-query model).
- G. Brassard, P. Høyer, A. Tapp, “Quantum cryptanalysis of hash and claw-free functions”, LATIN 1998 (collision search, 2^(n/3)).
- CycloneDX 1.6, cryptographic bill of materials.